WORKSHOP · SECURE AI IN HIGHER EDUCATION

Building a Secure Internal AI System for Higher Education

Architecture, governance, and human-in-the-loop design for institutions moving off public cloud AI.

Nguyen Thanh Tuan

Vietnam–Korea University of ICT · The University of Danang

nttuan@vku.udn.vn

univ-cotedazur.eu/events/digital-week

TODAY'S PATH

An hour, in five parts

01	The Problem — what public AI puts at risk	8 min
02	The Blueprint — a seven-layer architecture	12 min
03	The Human Layer — oversight and governance	6 min
04	In Practice — use cases and trade-offs	4 min
05	Your Turn — design a secure workflow	30 min

THE PROBLEM · CONTEXT

AI is already in the classroom — the only question is whether it runs on infrastructure we control.

BRAINSTORMING

Drafting ideas, outlines, and first attempts at assignments.

SUMMARIZATION

Condensing readings, lecture notes, and dense source material.

LITERATURE DISCOVERY

Finding and connecting papers across a research field.

THE PROBLEM · THE STAKES

“Every prompt to a public model is a data transfer you don't control — and our people aren't only sending casual questions.”

Student records, unpublished research, and proprietary knowledge can be exposed through a single prompt or document upload — often without anyone realizing a line was crossed.

THE PROBLEM · FOUR RISKS

Four risks institutions can't ignore

01 · Data Privacy & IP

PII and unpublished research can leave the institution through prompts and uploads — and never come back.

02 · Output Accuracy

Hallucinations — confidently wrong outputs — are hard to catch and dangerous in grading and discovery.

03 · Regulatory Compliance

GDPR, FERPA (US), and CCPA (US) impose strict duties on how student data is handled and where it travels.

04 · Algorithmic Bias

Unmonitored models can produce uneven outcomes across student populations, eroding fairness and trust.

THE PROBLEM · A CONCRETE LOOK

What leaks with every prompt

PASTING STUDENT ESSAYS

Names, student IDs, and protected academic records leave the institution as one batch.

A FERPA-protected record, transferred to a system you don't control.

SUMMARIZING A MANUSCRIPT

Unpublished research — months of original work — sits on a third party's servers.

Intellectual property and competitive edge, exposed before publication.

PART TWO

The Blueprint

A modular, local-first architecture that keeps every sensitive step on infrastructure the institution controls.

02

Five design principles

Privacy by design	Data protection is embedded in every layer — not added as an afterthought.
Local-first processing	On-premises or private-cloud deployment keeps sensitive data inside our control boundary.
Human oversight	A qualified person can review and override AI output where it matters most.
Modular extensibility	New techniques — RAG, federated learning, differential privacy — slot in without a redesign.
Accuracy assurance	Hallucination detection and grounding actively reduce factual errors in output.

A seven-layer architecture

Data flows downward —
only the minimum passes between layers.

L1	User Layer	Role-based access control for students, faculty, and administrators.
L2	AI Access Gateway	Authentication, session management, and request routing.
L3	Input Safety Layer	PII detection, prompt-injection prevention, and input validation.
L4	RAG Knowledge Layer	Grounds responses in verified institutional sources, with citations.
L5	LLM Core	On-prem or private-cloud inference with calibrated confidence scores.
L6	Output Control Layer	Hallucination detection and factual consistency checks against sources.
L7	Audit & Governance	Tamper-evident logging and compliance with GDPR, FERPA, EU AI Act.

THE BLUEPRINT · LAYERS 1–3

Access and input safety

The front door — everything that happens before the model sees a single word.

L1 · User Layer

Role-based access control

Students, faculty, and administrators each get permissions matched to their actual needs — no more.

L2 · Access Gateway

Authentication & routing

Only authenticated, authorized requests reach the inference pipeline — sessions managed and routed.

L3 · Input Safety

Redact before it reaches the model

PII detection, prompt-injection defense, and input validation — the first line against exposure and attack.

Grounding and inference

Where the answer is built — and made traceable to verified sources.

L4 · RAG Knowledge Layer

Ground answers in our own sources

Syllabi, policies, and research repositories are indexed for semantic search. Responses arrive with citations — and accuracy depends on keeping that knowledge base clean and current.

L5 · LLM Core

Our model, with a confidence score

On-premises or private-cloud deployment keeps inference in-house. Every response carries a calibrated confidence estimate — the signal that drives human review downstream.

Output control and audit

The safety net and the paper trail — what makes the system accountable.

L6 · Output Control Layer

Catch hallucinations before delivery

Generated claims are compared against retrieved sources for factual consistency. Drift from the evidence raises a flag — and routes the answer to a human.

L7 · Audit & Governance

A tamper-evident record of everything

Every action and decision is logged with cryptographic signatures — enabling forensic review and compliance with GDPR, FERPA (US), and the EU AI Act.

THE BLUEPRINT · END TO END

The request–response workflow

1

Authenticate

Validate credentials against RBAC policies.

2

Sanitize

Redact PII; filter prompt-injection patterns.

3

Retrieve

Semantic search ranks relevant sources.

4

Infer & Score

Generate a response with a confidence score.

5

Validate

Check claims against retrieved sources.

6

if confidence < 70%

HITL Review

Low-confidence output routes to a human.

7

Deliver

Send with citations and confidence metadata.

8

Audit Log

Record every step with tamper-evident signatures.

The privacy-preserving toolkit

Complementary techniques — chosen per use case, each with its own trade-off.

Differential Privacy	Publishes aggregate statistics without exposing individual student records.
Federated Learning	Trains across institutions while raw data stays home — only updates are shared.
Homomorphic Encryption	Computes directly on encrypted data — best for bounded, specific tasks.
Secure Multi-Party Computation	Enables joint analysis across institutions with no party revealing raw data.
Retrieval-Augmented Generation	Grounds answers in verified sources with real-time citations and fact-checking.

PART THREE

Keeping Humans in the Loop

Oversight that protects academic standards — calibrated so reviewers stay sharp, not swamped.

03

70%

THE CONFIDENCE THRESHOLD

Below this line, a human reviews before delivery.

Confident answers flow through automatically; uncertain ones pause for faculty or staff review. The threshold is a dial — institutions tune it to their own accuracy-versus-speed trade-off and the sensitivity of each task.

An illustrative default — not a fixed standard. Calibrate it per task on your own data; the principle (gate uncertain answers to a human) matters more than the exact number.

THE HUMAN LAYER · WHERE HUMANS STEP IN

Five points of human oversight

01 Pre-exposure review

Faculty vet AI explanations before students receive them.

02 Assessment safeguards

Confidence thresholds keep low-quality output out of exams.

03 Ethical research oversight

Faculty supervise literature summarization and hypothesis tools.

04 Grading validation

Every AI grading recommendation gets a human sign-off.

05 Bias monitoring

Outputs are continuously checked for demographic disparities.

★ The common thread

Humans own high-stakes calls; the machine handles the volume.

Preventing reviewer fatigue

Ask humans to review everything and they review nothing. Three habits keep oversight meaningful:

Rotate assignments

Spread the review load so no single person carries it long enough to go numb.

Clear escalation

Give reviewers an obvious path for hard cases — no guessing about what to do next.

Reserve mandatory review

Require human sign-off only for low-confidence output and sensitive domains.

A unified governance framework

Role-based access

Differentiated permissions for students, faculty, and admins.

Usage policies

Clear acceptable-use, prohibited-use, and data-handling rules.

Tamper-evident audit

Cryptographically signed logs for forensic accountability.

Compliance monitoring

Real-time checks for GDPR, FERPA (US), and policy violations.

XAI transparency

Decision explanations that support human understanding and override.

FRIA & DPIA reviews

Regular impact assessments aligned with the EU AI Act.

PART FOUR

In Practice

Real use cases and the honest cost of bringing AI inside your institution.

04

Three domains of use

TEACHING

RAG tutor grounded in lecture slides and course texts

AI-drafted grading with faculty approval

Writing and programming feedback within policy

RESEARCH

Literature summaries from local repositories

Faculty-supervised hypothesis generation

Draft writing that keeps IP in-house

ADMINISTRATION

Course scheduling within real constraints

First-line student inquiries with escalation

Document processing with full audit trails

Benefits and honest trade-offs

WHAT WE GAIN

Local data control — supports GDPR and FERPA directly

Audit trails and explainability build institutional trust

Models fine-tuned to our curriculum and culture

Unpublished research and IP stay in-house

WHAT IT COSTS

GPU infrastructure from **$50K to $500K+**

Operational complexity — staff, governance, security ops

Open-source models may trail commercial ones in some domains

Privacy techniques carry real utility trade-offs

PART FIVE · 30 MINUTES

Your Turn: Design a Secure Workflow

In groups, apply the seven-layer architecture and the 70% threshold to a real academic scenario. Aim for defensible, not perfect.

Get the materials

Scan for the slides, worksheet & hands-on notebooks.

`tinyurl.com/2bzedl2s`

05

ACTIVITY · STEP ZERO

Choose your scenario

Pick one as a group — you'll design and defend it.

Scenario A

AI-Assisted Grading System

Generates feedback and suggested scores for student essays.

Scenario B

IP-Protected Research Assistant

Summarizes unpublished manuscripts and identifies research gaps.

ACTIVITY · STEPS 1 & 2

Assess the risks, then apply the layers

Step 1 · Risk

5 min

Name two critical risks of using public AI.

Data privacy & IP — what could leak?

Integrity & accuracy — where do hallucinations hurt?

Step 2 · Configure four layers

15 min

L1 · Access

Who may use it, and what are their limits?

L3 · Input Safety

Which PII or keywords must be redacted?

L4 · RAG

Which institutional sources will ground it?

L6 · Output Control

How do you verify against the sources?

ACTIVITY · STEP 3

Design the human checkpoint

10 min

THE 62% TEST

Your AI returns a result at 62% confidence.

It's below the 70% threshold. Map the exact steps the faculty reviewer takes before it reaches the end user.

GUARD THE REVIEWER

Now keep that reviewer from burning out.

Spell out your fatigue strategy — rotation, escalation, and what you deliberately choose not to review.

ACTIVITY · EVALUATION

Evaluate your design

Total · / 20

CRITERION	DEVELOPING · 1–2	PROFICIENT · 3–4	EXEMPLARY · 5
Security & Privacy	Data leak risks named but no specific mitigation designed.	Basic PII filters and user roles identified.	Full Layer-3 sanitization and local-first data sovereignty.
Grounding & Accuracy	AI use proposed but no grounding or source verification.	Uses RAG, but sources are loosely defined.	Layer-4 RAG with citations and Layer-6 consistency checks.
HITL Effectiveness	Human review mentioned but triggers and process undefined.	A review process exists, but triggers are unclear.	Clear 70% threshold with a fatigue-mitigation strategy.
Institutional Value	Need identified but cost and operational complexity ignored.	Addresses a need, but ignores infrastructure cost.	Balances operational complexity against clear benefits.

— THANK YOU · DISCUSSION

Bring AI inside the walls — controlled, grounded, and human-supervised.

A conceptual framework, not a finished product — the real test is the pilot. What did your group design?

Nguyen Thanh Tuan

nttuan@vku.udn.vn · Vietnam–Korea University of ICT, University of Danang

Get the materials

Slides · Worksheet · Notebooks

`tinyurl.com/2bzedl2s`